Техническая база знаний и проектные заметки решения «ВТБ Защита»

> **Единый репозиторий технических деталей, архитектурных решений, протоколов интеграции и ответов на критические вопросы.**
> Файл предназначен для фиксации и быстрого извлечения технических подробностей при подготовке материалов, слайдов и защиты перед жюри.

---

1. Юридическая и регуляторная база: Защита «ВТБ Сейф / Money Lock» (Tier 2)

1.1. Законность добровольного 24-часового Time-Lock (ст. 421, 845, 858 ГК РФ)

- **Принцип добровольности (Opt-in, ст. 421 ГК РФ):** Сервис подключается клиентом добровольно через акцепт оферты ДБО. Банк не блокирует счета принудительно, а предоставляет функционал самоограничения.
- **Соответствие ст. 845 и ст. 858 ГК РФ:** Банк не ограничивает права клиента в одностороннем порядке. Задержка в онлайне — согласованный клиентом регламент проведения операций по специальному сберегательному счету («Cold Vault»).
- **Аналоги в РФ:** Срочные вклады с регламентом досрочного расторжения (ст. 837 ГК РФ), добровольные суточные лимиты на СБП («0 руб.»), накопительные счета.
- **Международный прецедент:** Программа *MAS Money Lock* (Сингапур: DBS, OCBC, UOB) — заблокировано >30 млрд SGD, 0% хищений, одобрено государственным финрегулятором.

1.2. Регламент экстренного доступа (Fail-Safe при ЧП / несчастье)

1. **Физический контур (Офис ВТБ):** Личный визит с паспортом снимает любые таймлоки немедленно. Присутствие человека исключает удаленную социнженерию. Деньги выдаются через кассу/счет мгновенно.
2. **Ликвидный кошелек (Hot Wallet):** Текущий дебетовый счет остается полностью мобильным 24/7 с операционным остатком на повседневные нужды и непредвиденные срочные траты (аптеки, скорая, ремонт).
3. **Emergency Bypass (Доверенное лицо, Tier 3):** Подтверждение пуш-уведомлением доверенным родственником в приложении «ВТБ Онлайн» позволяет отменить 24ч ожидание дистанционно (например, если клиент в больнице).

1.3. Техническая архитектура и двухконтурная модель: Hot Chain vs Cold Chain

- **Концепция Hot / Cold Chain:**

- **Hot Chain («Горячий контур» / Hot Wallet):**
  - *Счета:* Текущие дебетовые карты, расчетные счета.
  - *Шлюзы:* Открыты для мгновенных платежей 24/7 (СБП, эквайринг, переводы card2card, снятие в АТМ).
  - *Защита:* Tier 1 «Смарт-Щит» (ML-скоринг 150 мс, 12 признаков ОБДС, Liveness Step-Up).
  - *Назначение:* Повседневные расходы, непредвиденные срочные траты.
- **Cold Chain («Холодный контур» / Cold Vault / ВТБ Сейф):**
  - *Счета:* Накопительные счета, депозиты, целевые сбережения.
  - *Шлюзы:* **Air-Gap изоляция.** Полностью отрезаны от СБП, интернет-платежей и АТМ.
  - *Ввод (Ingress):* Мгновенный 24/7 (входной трафик без трения).
  - *Вывод (Egress):* Единственный маршрут — обратный перевод в свой Hot Chain через **24-часовой Time-Lock** (или мгновенно лично в офисе с паспортом).
  - *Назначение:* 100% защита накоплений жизни от социальной инженерии.

- **Стейт-машина разблокировки (24-hour Time-Lock Workflow):**
  1. *Инициация:* Клиент в приложении нажимает «Перевести из Сейфа на карту».
  2. *Старт таймера:* Запускается таймлок ровно на 24 часа. Счёт переходит в статус `PENDING_UNLOCK`.
  3. *Мультиканальный алерт:* Клиенту уходит SMS + Push: «Запрошен вывод X руб. Деньги поступят на карту через 24 часа. Если это делаете не вы, нажмите кнопку отмены».
  4. *Право мгновенной отмены (Kill-Switch):* В течение 24 часов в приложении горит красная плашка отмены. Клиент (или если мошенник заставил начать вывод, а жертва опомнилась через пару часов) в 1 клик прерывает процесс.
  5. *Исполнение:* Через 24 часа деньги падают на дебетовый счет, откуда их можно тратить.

- **Начисление процентов:** Во время нахождения средств в «Сейфе» и во время 24-часового периода ожидания процентный доход начисляется в полном объеме (в отличие от досрочного расторжения вклада).

1.4. Защита от вектора «Снятие в банкомате» (АТМ-защита)

- **Проблема:** Мошенники часто заставляют жертву пойти к банкомату и снять наличные, чтобы обойти блокировки СБП.
- **Решение в Tier 2:**
  - Со счета «Сейфа» прямая выдача наличных в АТМ **заблокирована** на уровне процессинга.
  - Даже после перевода средств из «Сейфа» на дебетовую карту через 24h Time-Lock включается регуляторный лимит ЦБ РФ: **не более 50 000 ₽ на 48 часов** при наличии признаков риска или нестандартного снятия всей суммы.
  - Крупные суммы наличных (от 100-300 тыс. ₽) выдаются **только в кассе отделения по паспорту** с обязательным скриптом антифрод-верификации сотрудником отделения.

1.5. Клиентский путь (UX/UI экраны в «ВТБ Онлайн»)

1. **Витрина:** Карточка «ВТБ Сейф» с иконкой замка и бейджем «Защищено Money Lock (0% риска хищения)».

2. **Активация:** 1 слайдер-переключатель «Заблокировать от дистанционного вывода» + согласие с офертой (Opt-in).
3. **Экран запроса вывода:** Ползунок суммы → крупный информационный блок: *«Средства поступят на карту завтра в 15:30. Это защищает ваши накопления от социнженерии. При ЧП вы можете забрать деньги сейчас в отделении с паспортом»* → Ввод кода подтверждения.
4. **Виджет ожидания:** Закрепленный желтый баннер вверху главного экрана с обратным таймером (23:59:59) и кнопкой **«Отменить вывод»**.

---

2. Архитектура скоринга и Liveness Step-Up (Tier 1 «Смарт-Щит»)

2.1. Тайминги и стек антифрод-пайплайна

- **Бюджет времени скоринга:** ровно **150 мс** на транзакцию.
- **Оркестратор событий:** Apache Kafka (Event Streaming) + Apache Flink (Stateful Stream Processing).
- **ML-ядро:** CatBoost Classifier на 100+ признаках (поведенческие фичи, граф связей, метаданные устройства, телеком-алерты).
- **Интерфейс верификации:** 15-секундный встроенный Liveness SDK (проверка живости лица: микро-движения, отражения экрана, 3D-маска) прямо в приложении «ВТБ Онлайн».
- **Защита от Deepfake/видеозвонков:** Запрос нативного случайного действия (моргание в заданном ритме, наклон головы по стрелке), анализ сенсоров акселерометра/гироскопа при съемке, сверка биометрии с ранее валидированным шаблоном профиля.

2.2. Разграничение регуляторных контуров (161-ФЗ vs Внутренний ML)

- **Черный список ЦБ РФ (База ФинЦЕРТ):** Если реквизит получателя в базе Банка России — **жесткая 48-часовая блокировка по закону 161-ФЗ без исключений** (Liveness Step-Up здесь не применяется, иначе банк нарушит закон и попадет под правило 100% компенсации за 30 дней).
- **Серая зона (Внутренние аномалии ВТБ):** Новый получатель, ночной перевод, нетипичная сумма, смена геолокации. Здесь вместо 48-часового хард-блока включается **Liveness Step-Up**, снимающий подозрение за 15 секунд.

---

3. Телеком-интеграция и проверка SIM / Устройств

3.1. Детекция смены SIM-карты (IMSI Shift)

- Запрос через интеграционную шину к операторам «Большой четверки» (МТС, Билайн, МегаФон, Т2) и собственному MVNO «ВТБ Мобайл».
- Проверяется **IMSI** (International Mobile Subscriber Identity) привязанной SIM-карты.
- При замене SIM на номер накладывается внутренний 48-часовой флаг повышенного риска (запрет на вход по SMS без доп. биометрии).

3.2. Детекция активного телефонного разговора (Признак ОБДС № 9)

- **Нормативная база:** Приказ Банка России от 05.11.2025 № ОД-2506 (**Признак № 9** — нетипичная телефонная активность / непрерывный разговор во время платежа).
- **Клиентский уровень (Mobile SDK в «ВТБ Онлайн»):**
  - **Android:** `TelephonyCallback` / `TelephonyManager.CALL_STATE_OFFHOOK` — фиксирует активный голосовой вызов в момент нажатия кнопки «Перевести».
  - **iOS:** `CXCallObserver` (фреймворк CallKit) — определяет факт активного голосового соединения (включая сотовую связь и мессенджеры).
- **Сетевой уровень (Телеком-шлюз ВТБ):**
  - Прямая интеграция с операторами («Большая четверка» + «ВТБ Мобайл») по протоколам HLR/HSS и антифрод-платформам.
  - Передача флага `is_on_call` в реальном времени даже при попытке скрыть статус на устройстве.
- **Влияние на ML-скоринг (CatBoost):**
  - Флаг `is_call_active = True` при переводе новому получателю имеет один из наивысших весов (feature importance в топ-3).
  - Риск-скор мгновенно переходит из зеленой зоны в критическую (красную/желтую).
- **Действие системы:**
  - Операция приостанавливается.
  - Поверх экрана выводится баннер-интервенция: *«Внимание! Вы сейчас разговариваете по телефону. Если собеседник представляется сотрудником банка или полиции и просит перевести деньги — это мошенники!»*.
  - Для продолжения транзакции требуется сбросить звонок и пройти Liveness Step-Up (видеоселфи).

---

4. Семейный контур и кредитный замок (Tier 3 «Защита близких Pro»)

4.1. Проблематика и вектор атаки

- **Вектор 1: Кредитный фрод.** Мошенники не просто крадут остаток, а заставляют жертву оформить предодобренный онлайн-кредит на 1–3 млн ₽ в «ВТБ Онлайн» за 2 минуты и перевести кредитные средства на «безопасный счет».
- **Вектор 2: Изоляция жертвы.** Мошенники запрещают жертве советоваться с семьей («подписка о неразглашении государственной тайны»).
- **Текущая проблема на рынке:** Базовые сервисы «второй руки» имеют проникновение <2% из-за сложного подключения и неудобства. В Tier 3 мы делаем бесшовную механику **Second-Party Consent**.

4.2. Механика «Кредитный замок» (Second-Party Consent)

- **Принцип работы:** Любая заявка на онлайн-кредит, кредитную карту или увеличение кредитного лимита требует цифрового подтверждения от Доверенного лица (родственника).
- **Стейт-машина:**
  1. Клиент оформляет онлайн-кредит в приложении.

2. Заявка переходит в статус `WAITING_TRUSTED_APPROVAL`.
3. Доверенному лицу приходит Push-уведомление с деталями: *«Ваш родственник (Иван Иванович) оформляет кредит на 1 200 000 ₽. Подтвердите операцию, если знаете о цели займа»*.
4. Если доверенное лицо отклоняет или не отвечает в течение 12 часов — выдача в онлайне блокируется. Для получения денег требуется личный визит в офис ВТБ.

4.3. Пре-алерты близким при атаке социнженерии (Early Warning)

- **Триггер:** Срабатывание признака ОБДС № 9 (разговор по телефону во время сессии ДБО) + нетипичная сумма перевода у уязвимого клиента (пожилые люди, резкая смена поведения).
- **Действие:** Пока жертва находится под гипнозом мошенников на линии, Доверенное лицо мгновенно получает Push-алерт:
  «Внимание: Ваш близкий сейчас разговаривает по телефону и пытается сделать крупный перевод. Срочно перезвоните ему или свяжитесь со службой заботы ВТБ».
- Это физически разрушает сценарий изоляции жертвы.

4.5. Интеграция с федеральным «Самозапретом на кредиты» (31-ФЗ через Госуслуги)

- **Законодательная база:** Федеральный закон от 26.02.2024 № 31-ФЗ (вступает в силу с 1 марта 2025 года).
- **Суть государственного механизма:** Гражданин через Госуслуги или МФЦ вносит отметку в БКИ о самозапрете на выдачу потребительских кредитов. При наличии отметки банк юридически не имеет права выдавать кредит (кредит аннулируется, банк не может требовать возврат). Снятие запрета происходит только на 2-й календарный день (период охлаждения).
- **Синергия в решении ВТБ (Госуслуги vs Tier 3):** | Параметр | **Госуслуги (31-ФЗ)** | **Tier 3: Кредитный замок ВТБ** | | :--- | :--- | :--- | | **Характер** | Радикальный/тотальный (полный бан во всех банках) | Гибкий/семейный внутри экосистемы банка | | **Сценарий** | Для тех, кто вообще никогда не планирует брать кредиты | Для экономически активных семей (кредит можно взять, но с согласия родных) | | **Снятие ограничения** | Долгое: заявление на Госуслугах + ожидание 2 дня | Мгновенно: подтверждение от родственника в Push |
- **Бесшовная интеграция в «ВТБ Онлайн»:**
  - Проверка статуса самозапрета через СМЭВ / БКИ при входе в кредитный раздел.
  - Витрина в приложении: кнопка *«Установить тотальный самозапрет через Госуслуги»* прямо из меню безопасности ВТБ (повышает регуляторный комплаенс и заботу о клиенте).

---

5. Премиум-контур: «ВТБ Защита Плюс» (Tier 4)

5.1. Позиционирование и юнит-экономика

- **Ценообразование:** 149 ₽/мес (или бесплатно в пакетах «Привилегия» и «Прайм» для состоятельных клиентов).
- **Бизнес-модель (B2C-подписка):**
  - Проникновение: 500 000 подписчиков (1,65% от 30,3 млн активных клиентов).
  - Валовая выручка: 500 000 × 149 ₽ × 12 мес = **894 млн ₽/год**.

- Партнерская модель (Страховщик: СОГАЗ / СК «Пульс»): 70% на страховой резерв и выплаты, 30% комиссионный доход банка = **268,2 млн ₽/год чистой прибыли**.

- **Стратегическая роль:** Превращает антифрод из «затратного центра» (Cost Center) в **генератор новой прибыли (Profit Center)**, полностью окупая все затраты банка на ИТ и безопасность.

5.2. Состав премиального продукта (3 ключевых компонента)

1. **Киберстрахование с покрытием Социальной Инженерии (до 1 000 000 ₽):**
   - *Уникальное УТП:* Стандартные банковские страховки отказывают в выплатах, если клиент сам назвал СМС-код или перевел деньги. «ВТБ Защита Плюс» **напрямую покрывает случаи психологического обмана (социнженерии)** при наличии талона-уведомления из МВД.
2. **Кибер-консьерж 24/7 (Выделенная SOS-линия):**
   - В приложении появляется красная кнопка **«SOS: Экстренная помощь»**.
   - Время ответа оператора — до **10 секунд** (отдельная очередь в колл-центре, минуя голосового робота).
   - Комплексная поддержка: удаленная блокировка всех ДБО, отзыв переводов, помощь в блокировке скомпрометированного профиля на Госуслугах, составление юридически грамотного заявления в полицию.
3. **Darknet & OSINT Мониторинг утечек персональных данных:**
   - Автоматический мониторинг баз даркнета, теневых форумов и Telegram-каналов по хэшам данных клиента (телефон, email, паспорт, номер карты).
   - Превентивное уведомление клиента: *«Обнаружена утечка вашего пароля на стороннем ресурсе. Рекомендуем сменить пароль и проверить привязанные сервисы»*.

5.4. Операционная модель «Кибер-консьержа» и защита от раздувания OPEX

- **Главный риск:** Нанимать дорогих инженеров ИБ (SOC-аналитиков с зарплатами 250k+) в колл-центр экономически нецелесообразно.
- **Решение: Двухуровневая модель (L1 Triaged Support → L2 SOC):**
  1. **Линия L1 (Выделенная группа премиум-операторов КЦ):**
     - Принимают звонок за 10 секунд.
     - Работают по жестким стандартизированным плейбукам (SOP).
     - В CRM оператора выведены 3 «красные кнопки»: *Мгновенный Kill-Switch всех ДБО*, *Отзыв транзакции по 161-ФЗ*, *Автогенерация пакета документов для МВД*.
     - ФОТ оператора стандартный для премиум-линии (~70-80 тыс. ₽).
  2. **Линия L2 (Дежурные эксперты Управления противодействия мошенничеству ВТБ):**
     - Подключаются только в 2–3% нестандартных юридических кейсов.
     - **Нормативная база (Положение Банка России № 683-П и 821-П):** Банк ВТБ как системно значимая кредитная организация (СЗКО) законодательно **обязан обеспечивать непрерывный круглосуточный (24/7/365) мониторинг и реагирование на инциденты ИБ** и передачу данных в АСОИ ФинЦЕРТ. Дежурная смена ИБ/SOC в ВТБ уже существует и содержится в рамках базовых регуляторных затрат банка — Кибер-консьерж не требует расширения их штата.

    - **Обоснование и структура распределения звонков (откуда 2–3% эскалации):** По бенчмаркам банковских Service Desk (ITIL) и практике инцидент-менеджмента антифрода:
        - **~55% звонков:** Превентивные алерты («Мне звонили якобы из ФСБ, я положил трубку, проверьте мой счет»). L1 проверяет активность, меняет пароль/токен ДБО, подтверждает безопасность.
        - **~35% звонков:** Типовое пост-событие («Я перевел деньги 10 минут назад, спасите»). L1 отрабатывает за 60 секунд: мгновенный Kill-Switch карт/ДБО, запуск стандартного протокола отзыва по 161-ФЗ через шлюз НСПК/ЦБ, выгрузка справки для МВД по шаблону.
        - **~7% звонков:** Установка вредоносного ПО / фишинг («Скачал файл по ссылке»). L1 принудительно обнуляет сессии и токены ДБО.
        - **2–3% реальной эскалации на L2 (Инженеров ИБ):** Требуют глубокого расследования — сложные многозвенные цепочки через юрлица и P2P-шлюзы, признаки сговора с инсайдерами, Sim-Swap с перехватом трафика, выгрузка и расшифровка сырых дампов сетевого трафика и логов мобильного SDK для Следственного комитета / МВД. Для всего остального инженер ИБ избыточен.

- **Расчет нагрузки и экономики выделенной группы:**
    - База: 500 000 подписчиков Tier 4.
    - Частота экстренных нажатий кнопки SOS: ~0,8% базы в месяц = 4 000 звонков в месяц (~130 звонков в сутки на всю РФ).
    - Для 130 звонков в сутки требуется всего **3-4 оператора в смене** (штат 16 человек для режима 24/7).
    - Годовой ФОТ группы L1: 16 чел. × 80 тыс. ₽ × 1,3 (налоги/соцвзносы) × 12 мес = **~20 млн ₽/год**.
    - **Соотношение:** Дополнительный OPEX (20 млн ₽) составляет **меньше 8%** от чистой прибыли Tier 4 (268 млн ₽/год). Продукт сверхрентабелен.

---

6. Российские банковские практики-первоисточники решений (Бенчмарк РФ)

Каждый уровень нашего решения опирается на проверенные практики ведущих российских финансовых институтов, дорабатывая их слабые места:

6.1. Первоисточники для Tier 1 («Смарт-Щит» / Liveness Step-Up)

- **Сбербанк (Биометрический Step-Up в СберБанк Онлайн):**
  Сбербанк первым в РФ внедрил биометрическую верификацию в мобильном приложении (через ЕБС и внутренний биометрический контур) для подтверждения входа и крупных переводов.
  Эволюция в решении ВТБ: В Сбере биометрия часто используется постфактум после блокировки счета. ВТБ внедряет **превентивный 15-секундный Liveness SDK прямо в процессе оплаты (In-Flow Step-Up)**, предотвращая сам факт блокировки и спасая честные покупки (кейс Никиты).
- **Т-Банк (Селфи при смене доверенного устройства):**
  Т-Банк использует запрос фото лица при входе с нового устройства или сбросе пароля. Мы масштабируем этот опыт на снятие риск-флагов по операциям в «серой зоне» ML.

6.2. Первоисточники для Tier 2 («ВТБ Сейф / Money Lock»)

- **Рыночный вакуум в банковском секторе РФ:**
  Ни у Сбера, ни у Т-Банка, ни у Альфа-Банка сегодня **нет изолированного сберегательного счета с защитным таймлоком**. Во всех банках накопительные счета доступны для мгновенного опустошения через СБП за 1 минуту, что является причиной >68% всех потерь населения.
- **Практики-первоисточники смежных механизмов:**
  - *Инвестиционные счета брокеров (Т-Инвестиции / ВТБ Мои Инвестиции):* Режим расчетов **T+1 / T+2** (где вывод средств занимает регламентное время клиринга) доказал свою психологическую устойчивость против мошенников — жертва успевает выйти из-под гипноза до завершения расчетов.
  - *Срочные вклады и сберегательные сертификаты Сбербанка (ст. 837 ГК РФ):* Механизм регламентного закрытия счетов с сохранением условий договора. ВТБ переносит эту логику в цифровой сберегательный счет с сохранением процентов.

6.3. Первоисточники для Tier 3 («Защита близких Pro»)

- **Сбербанк — сервис «Близкие рядом» (Концепция «Второй руки»):**
  Сбербанк первым протестировал механику подтверждения переводов пожилых родителей назначенным родственником через пуш-уведомления.
  Эволюция в решении ВТБ: Сервис Сбера покрывает только исходящие переводы и имеет охват <2%. ВТБ развивает эту практику в **«Кредитный замок» (Second-Party Consent на онлайн-кредиты)**, перекрывая главную угрозу — кредитный фрод на миллионы рублей, а также добавляет пре-алерты при звонках мошенников.
- **Т-Банк и «Т-Мобайл» (Телеком-шлюз и детекция звонков):**
  Т-Банк доказал эффективность симбиоза банка и собственного MVNO: фиксация активного телефонного разговора во время сессии ДБО снижает риск успешной социнженерии на 75%. ВТБ использует аналогичный протокол через интеграцию с «ВТБ Мобайл» и «Большой четверкой» (Приказ ЦБ № ОД-2506, Признак № 9).
- **Государственный первоисточник (31-ФЗ):**
  Интеграция с сервисом самозапрета на кредиты через Госуслуги и квалифицированные БКИ.

6.4. Первоисточники для Tier 4 («ВТБ Защита Плюс»)

- **Т-Банк — программа «Защитим или вернем деньги» (Платформа «Т-Защита»):**
  Первоисточник монетизации и компенсации социальной инженерии в РФ. Т-Банк включил гарантию возврата средств в премиальные подписки при соблюдении правил безопасности.
  Эволюция в решении ВТБ: Мы масштабируем это в полноценный страховой андеррайтинг (партнер СОГАЗ) с лимитом **до 1 млн ₽**, покрывающий телефонный обман при наличии заявления в МВД.
- **Сбербанк Страхование — полис «Защита от киберугроз / Сбереги финансы»:**
  Первоисточник классического розничного киберстрахования в РФ. ВТБ усиливает продукт операционной составляющей — **выделенной линией Кибер-консьержа (L1/L2) с ответом за 10 секунд** на базе круглосуточной дежурной смены по Положению ЦБ № 683-П.